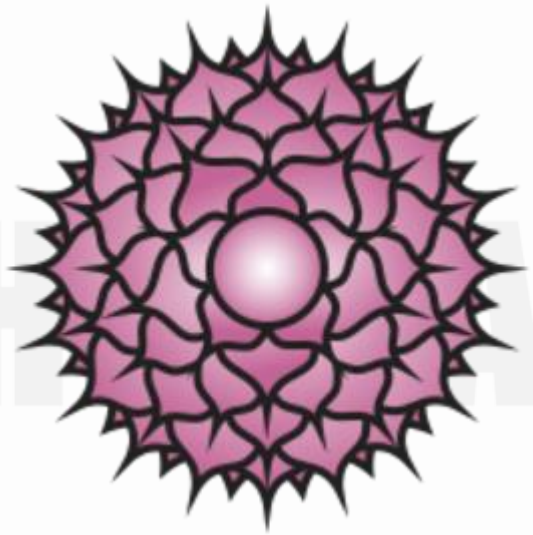
CYBERSECURITY 101

Presented By : A3h1nt

Rules

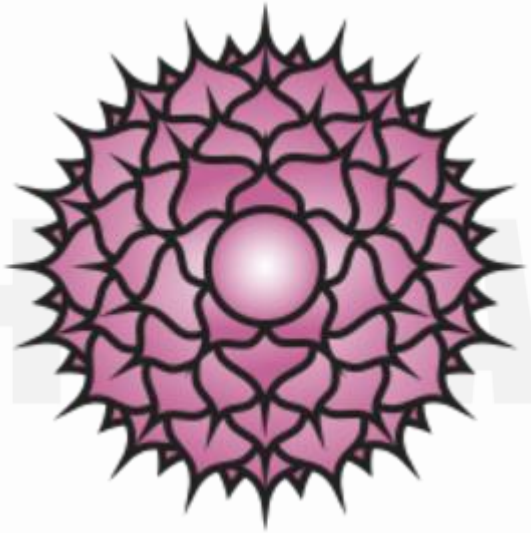
- Note down your questions.
- Do not interrupt others.
- Keep it decent, keep it cool.
- Understand concepts, not cram them.



[A3h1nt]

Suggestion Before You Start

- Make notes.
- Ask as many questions as you can.
- Revise things the same day, it'll only take 30 mins.
- Better ask, than being a fool for the rest of your life.



[A3h1nt]

Week – 1

Presented By : A3h1nt

Topics

- Introduction to hacking and it’s history
- Introduction to cybersecurity and it’s history
- Understanding asset, risk, threat, vulnerability and risk equation.
- CIA Triad
- CVSS Score
- Risk Management
- Incident Response
- Cybersecurity Teams
- Cybersecurity Frameworks
    - NIST
    - ISO27001
    - PCI-DSS

SURAKSHYAAN

What is hacking?

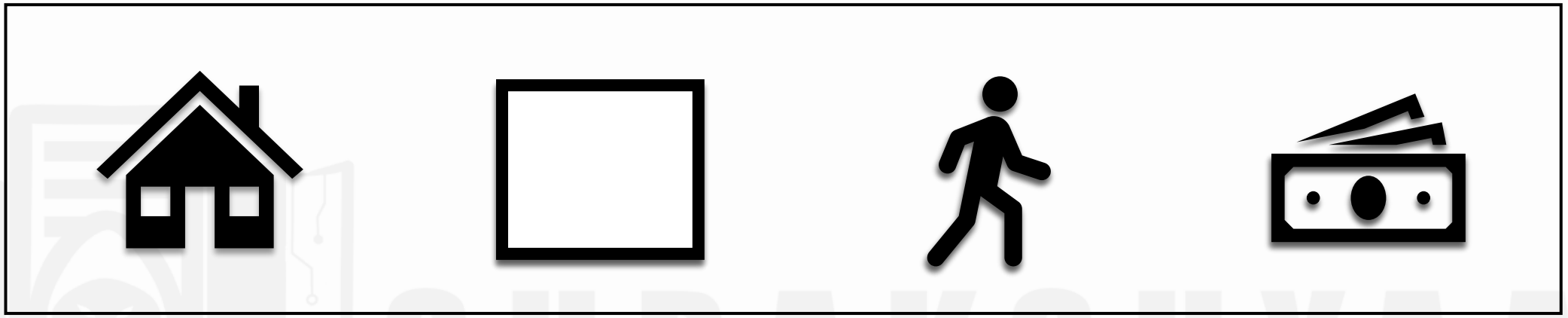
What is hacking?

“If you can’t define something, you don’t understand it well enough”

– Albert Einstein

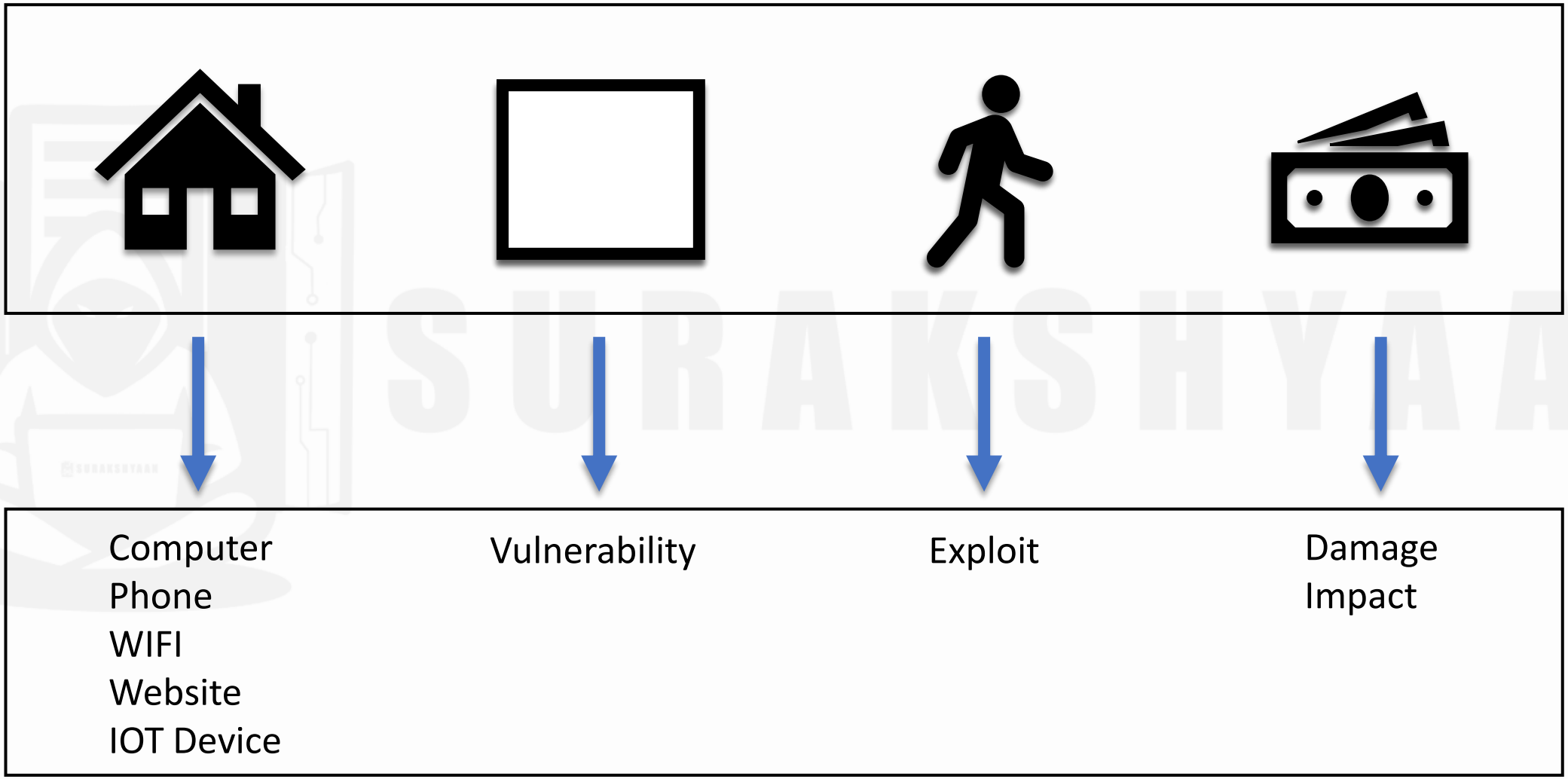
SURAKSHYAAN

An Analogy



SURAKSHYAAN

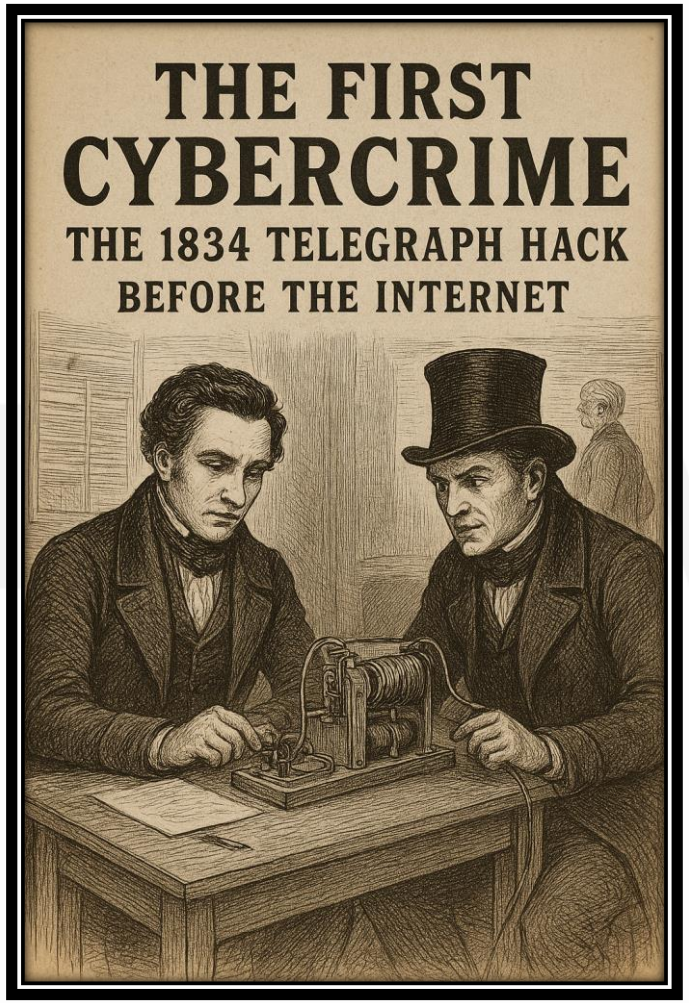
An Analogy



SURAKSHYAAN

History Of Hacking

- First recorded event of cybercrime happened in 1834 by the Blanc Brothers.
- They successfully tricked a telegraph operator to give out sensitive information from the French Telegraph System about stock market.
- This means “hacking” is not limited to just computers.
- With advancement in tech and introduction of computing, hacking became more prevalent. Read about Woz and Kevin Mitnick.



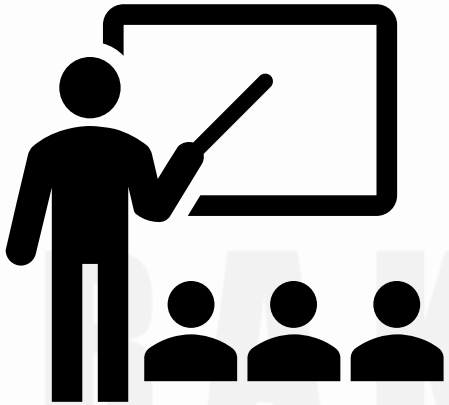
What is hacking?

“Hacking is the art of making something, intentional, do unintentional things” – A3h1nt

Few Examples

Something Intentional	Lock
Intention	Unlock using a key
Unintentional	Unlock using paper clip

Few Examples



Something Intentional	School Management System
Intention	Student should only view scores
Unintentional	Student being able to change scores

What is cybersecurity?

Story Time

- The first malicious programme, Creeper.
- Infected entire ARPANET.
- Leaving a message on all infected computers "*I AM THE CREEPER, CATCH ME IF YOU CAN*".
- First anti-virus software, Reaper.
- It was developed to get rid of Creeper.
- Both creeper & reaper were self-replicating worms.

What is cybersecurity?

“Cybersecurity is a field of computer science that deals with protecting people, systems and data.” – The Internet

What is an asset?

Asset

- An asset is anything of value.
- Something that you are trying to protect.
- Could be a computer, network, phone, document etc.

SURAKSHYAAN

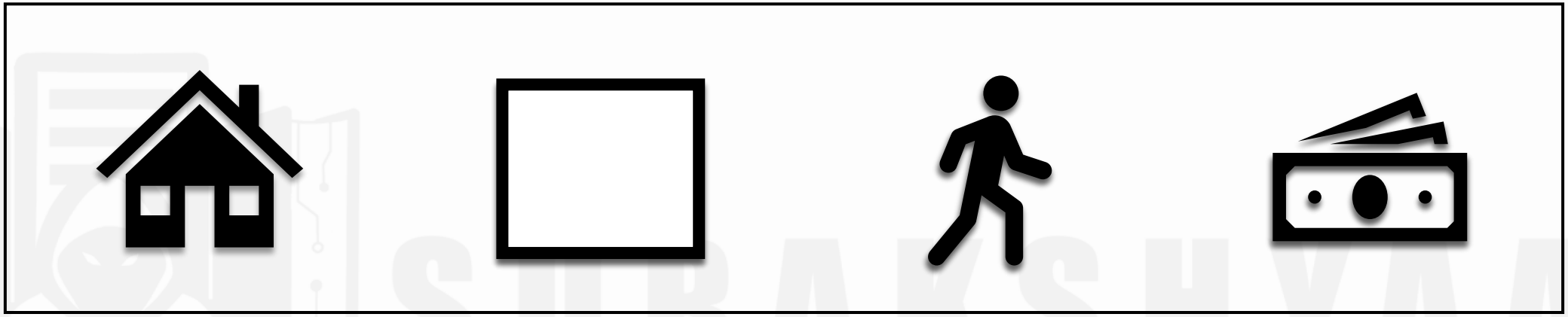
Threat, Vulnerability & Risk

- A **threat** is a possibility of something bad that might happen.
- A **vulnerability** is a weakness in the asset or in systems protecting it, that might allow a threat to materialize.
- A **risk** is the total potential impact, if a vulnerability is exploited by a threat actor.

Risk = Threat x Vulnerability

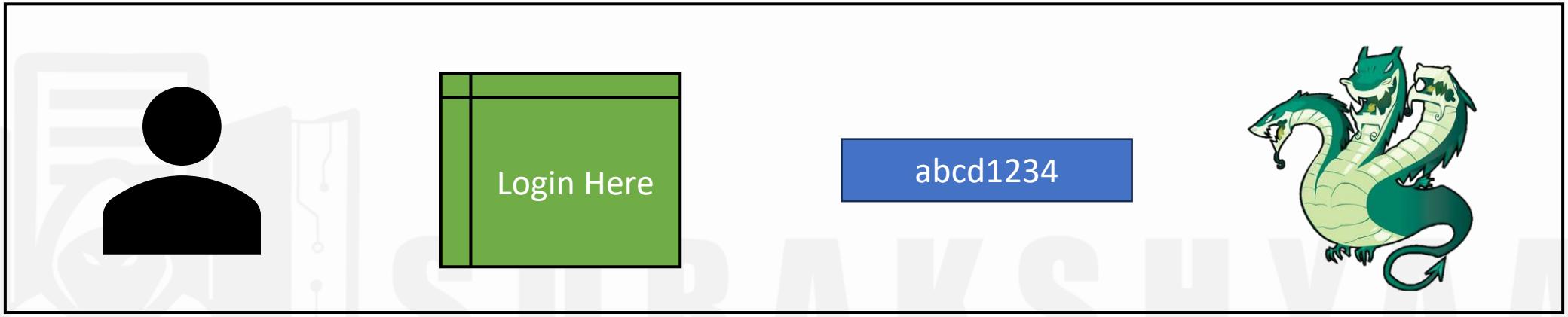
SURAKSHYAAN

Example 1



Asset	Money, Jewellery, Property Papers etc.
Vulnerability	A broken window
Threat	A thief might enter through the broken window
Risk	Loss of wealth, loss of reputation and maybe loss of life

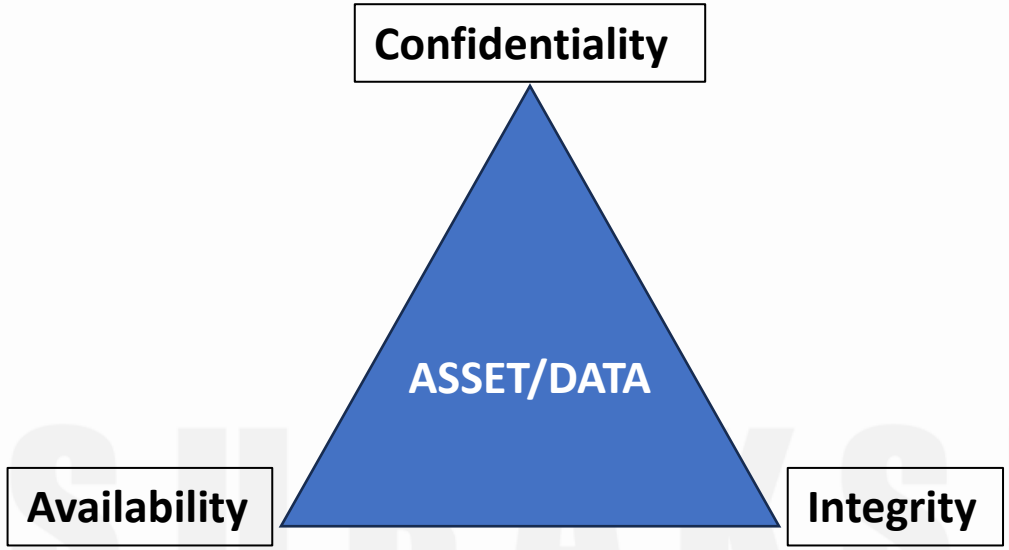
Example 2



Asset	User Account/User Data
Vulnerability	Weak passwords allowed
Threat	Someone might be able to guess the password
Risk	Loss of account access, loss of data, loss of reputation

CIA Triad

CIA Triad



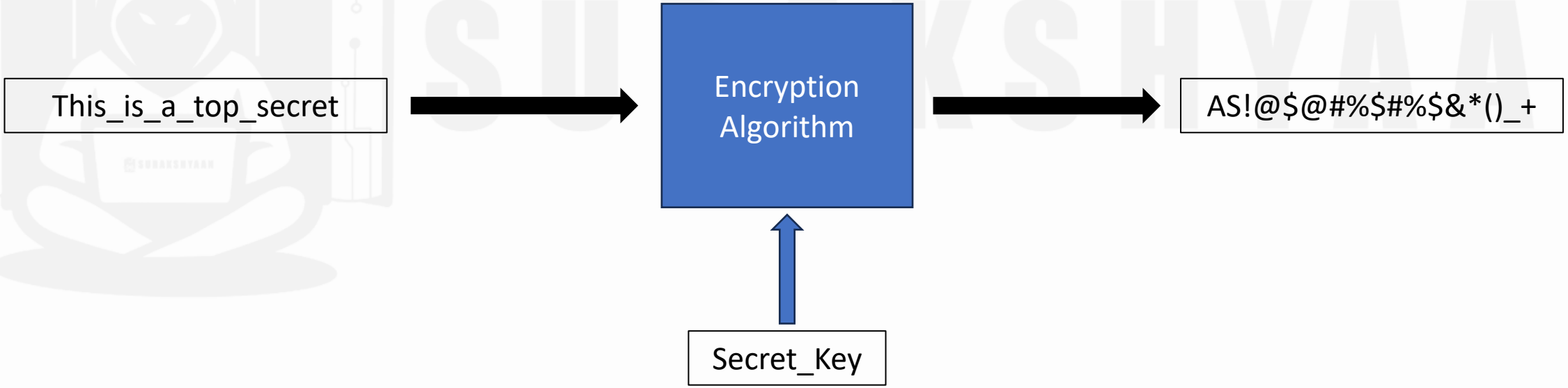
- CIA stands for confidentiality, integrity and availability.
- A CIA triad defines what aspects of an asset we are trying to protect.
- It says a secure system should be capable keeping Confidentiality, Integrity & Availability of data intact.

Confidentiality

- The data should remain confidential to unauthorised access.
- Only authorised party should be allowed to access it.
- Confidentiality is achieved through encryption.

Encryption

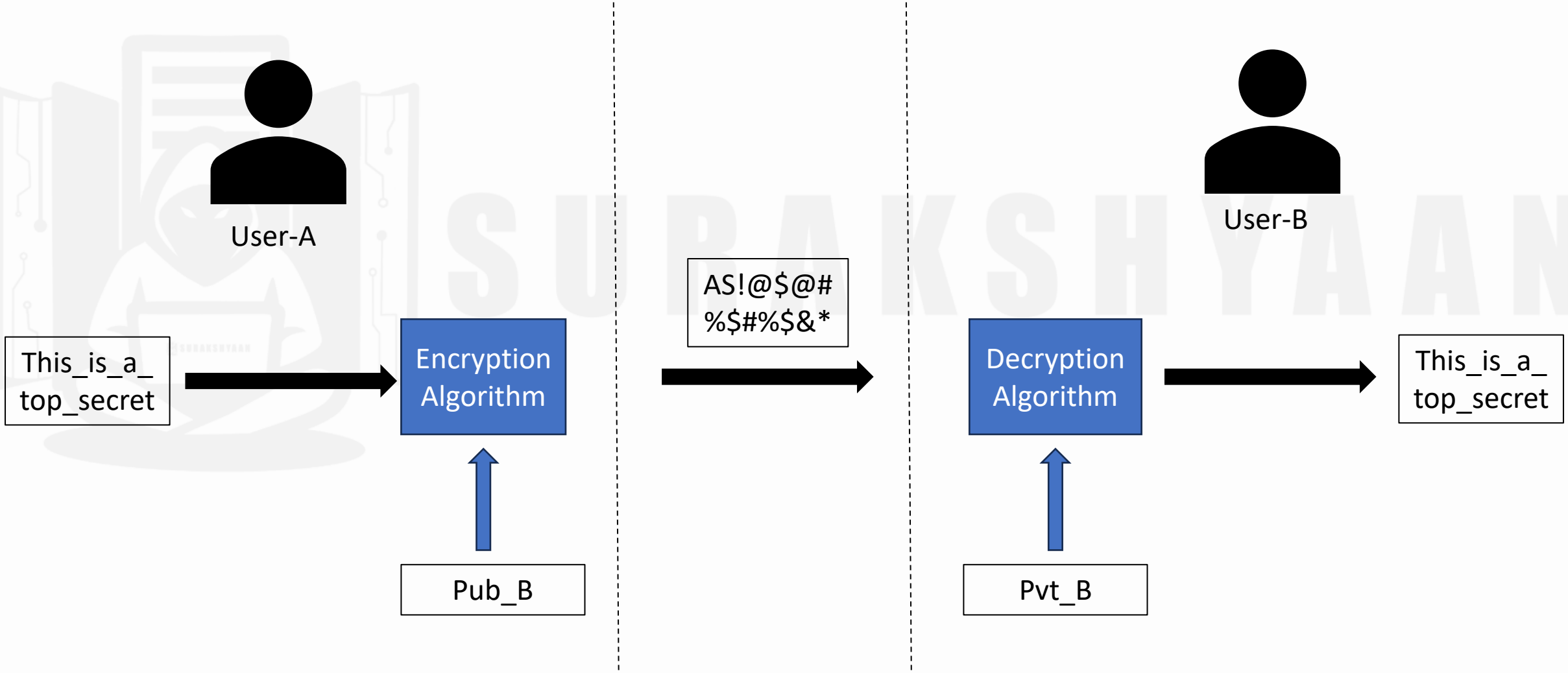
- Encryption is the process of transforming plain text into a string of characters, using a secret key.



Encryption

- Encryption is of two types symmetric and asymmetric.
- **Symmetric** : A single key is used of encryption and decryption. Example: AES
- **Asymmetric** : A pair of keys is used for encryption and decryption. Example: RSA
  - *Private Key* : Remains private to the user.
  - *Public Key* : Remains public.

Asymmetric Encryption



Integrity

- The data should remain in it’s intended state.
- No unauthorised changes should be made to data.
- Integrity is achieved through hashing.

Hashing

Hashing

- Hashing is a one-way function, that generate a fixed length output for any length of input.
- It cannot be reversed.
- “Abc” & “abc” will generate an entirely different hash.

File Integrity Check

- We can verify the authenticity of a file using hashing.

Availability

- The data should be available as and when required.
- Availability is achieved through things like.
  - Data Redundancy
  - Load Balancing

ASSE/DATA
SURAKSHYAAN

CVSS Score

CVSS Score

- Stands for common vulnerability scoring system.
- A metric to determine the severity of a vulnerability.
- An industry standard, used everywhere.
- Latest version 4.0, but 3.0 is also used.

Severity	Score
Low	0.1 - 3.9
Medium	4.0 - 6.9
High	7.0 – 8.9
Critical	9.0 – 10.0

Risk Management

Risk Management

- Risk management refers to the process of managing a risk.
- There are 4 steps involved in a risk management process.

1. **Identify** : Identifying the potential risks.
2. **Analyse** : Analysing them and prioritising them.
3. **Mitigate** : Patching the identified issues.
4. **Monitor** : Monitoring to confirm if the patch worked.

Incident Response

Incident Response

- Incident response is a plan that an organisation follows to detect and respond to a cybersecurity incident (data breach, network compromise).

- There are 6 steps involved in an incident response plan.

1. **Preparation** : Preparing the incident response plan.
2. **Detection** : Detecting the security incident.
3. **Analysis** : Analysing the security incident. (How, intent)
4. **Containment** : Preventing it from spreading into surroundings.
5. **Eradicate** : Neutralising the threat, killing it.
6. **Recovery** : Recovering systems back to their normal state.

SURAKSHYAAN

Incident Response – Your Plan

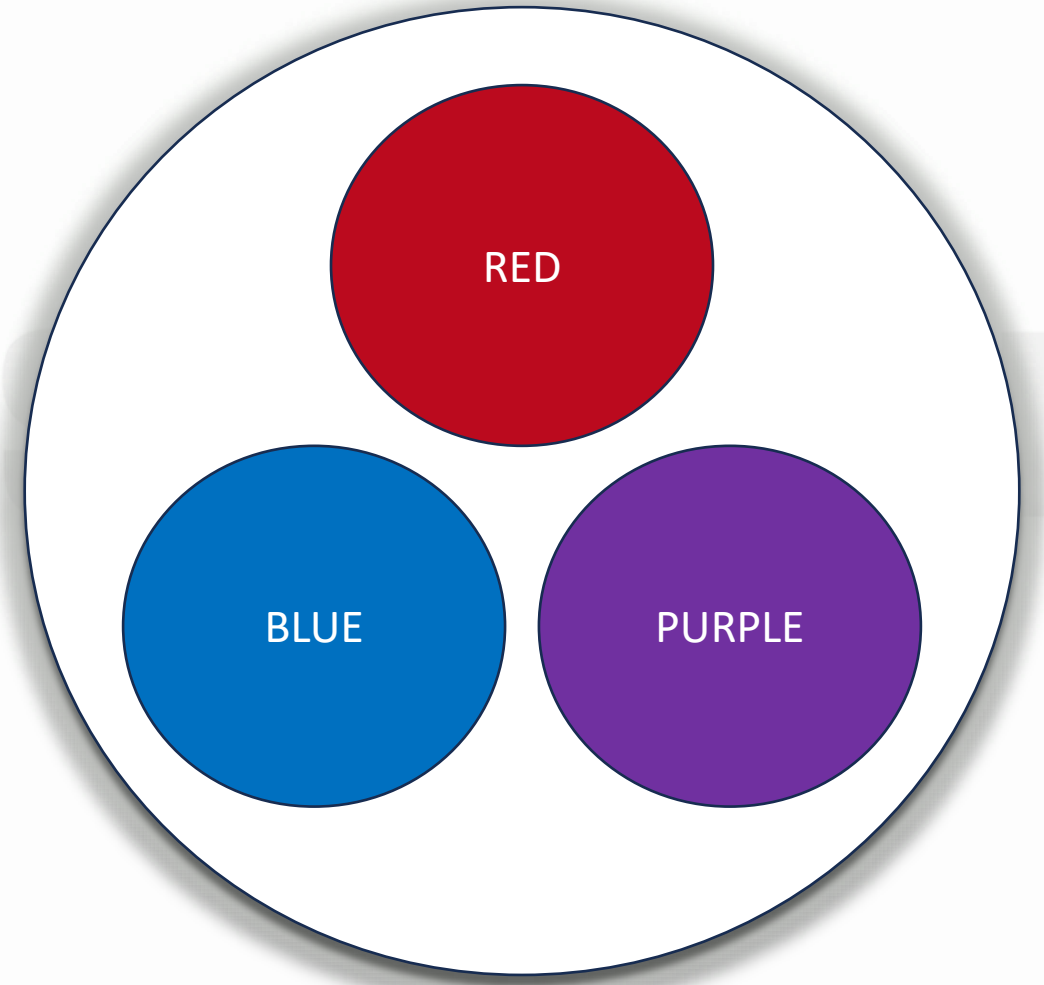
1. **Preparation** : Preparing your plan.
2. **Detection** : You would typically use an anti-virus software.
3. **Analysis** : You will then analyze the identified malicious file.
4. **Containment** : You will disconnect other connected components.
5. **Eradicate** : You will remove the malicious file.
6. **Recovery** : You will recover things back to their original state.

The Difference

Risk Management	Incident Response
Risk management is an ongoing process and it's not just limited to computers or networks.	Incident response is the immediate process implemented after an incident.

Cybersecurity Teams

Cybersecurity Teams



Red Team

- Guys who attack/hack
- Roles :
  - Penetration Tester
  - Ethical Hacker

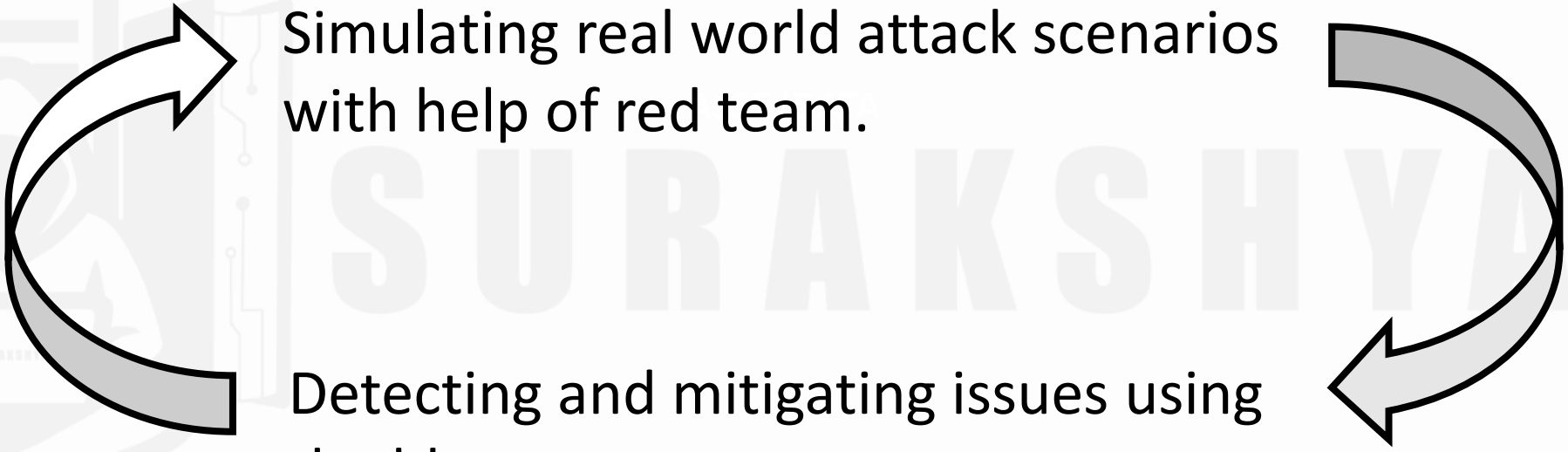
Blue Team

- Guys who defend/prevent
- Roles :
  - Incident Response
  - SOC Roles

Purple Team

- Guys who attack & defend

What’s happening exactly?



SURAKSHYAAN

Methodology Simplified

Information Gathering

Vulnerability Finding

Exploitation

Reporting

Cybersecurity Framework

Cybersecurity Frameworks

Framework	Purpose	Origin
NIST CISF	Guidelines for general cybersecurity risk management.	NIST – US National Institute Of Standards & Technology.
ISO-27001	Guidelines for managing ISMS (Information security management systems)	International Organization for standardization (ISO) & International Electrotechnical Commission (IEC)
PCI-DSS	Guidelines for companies processing payments to protect card holder's data.	Combined effort of many credit-card companies.

Week – 2

Presented By : A3h1nt

Topics

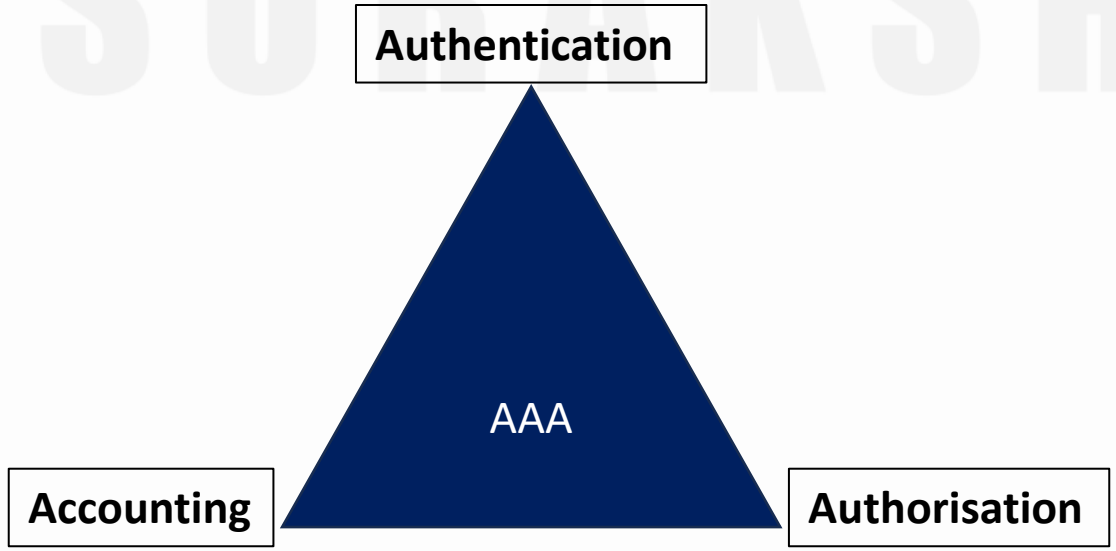
- Cybersecurity Approaches
  - AAA Framework
  - Defence In Depth
- Man In Middle Attack
  - Digital Certificates
  - SSL
- Password Hacking
  - A Good Password
  - Password Storage
- Social Engineering
- Malware Family
- DOS & DDOS
- Zero Days
- APT Groups
- Disclosure Programs
  - VDP
  - Bug Bounty

SURAKSHYAAN

Cybersecurity Approaches

AAA

- Authentication, Authorisation & Accounting.
- Defines how a user's interaction should be managed or processed around an asset.



AAA - Authentication

- Every user accessing the asset, must authenticate themselves.
- How can a user be authenticated?
  - Something you know.
  - Something you have.
  - Something you are.
- Authentication can be of two types
  - Single Factor Authentication
  - Two Factor Authentication

SURAKSHYAAN

AAA - Authorization

- Every user should have a role and corresponding permissions to that specific role.
- No user should have any extra permission/privilege.
- How do we implement authorization?
  - By assigning permissions based on user role.
- Principle Of Least Access
  - Every user should have least amount of privilege/access by default.
  - Any extra permissions required should be explicitly given.

AAA - Accounting

- Each and every user interaction with the asset should be logged.
- Regular log backups should be made.

```
192.168.1.1 [24/Apr/2024:23:01:12] HTTP/1.1    200
192.168.1.1 [24/Apr/2024:23:01:12] HTTP/1.1    200
192.168.1.1 [24/Apr/2024:23:01:13] HTTP/1.1    204
192.168.1.1 [24/Apr/2024:23:01:14] HTTP/1.1    200
192.168.1.1 [24/Apr/2024:23:01:15] HTTP/1.1    200
192.168.1.1 [24/Apr/2024:23:01:16] HTTP/1.1    200
192.168.1.1 [GET /home HTTP/1.1    HTTP/1.1    1024
192.168.1.1 [GET /about HTTP/1.1   HTTP/1.1    2048
192.168.1.1 [GET /images/logo.png  HTTP/1.1    4096
192.168.1.1 [GET /css/style.css    HTTP/1.1    200
192.168.1.1 [GET /js/app.js        HTTP/1.1    1024
192.168.1.1 [GET /contact HTTP/1.1 HTTP/1.1    4096
192.168.1.1 [GET /jspap.jsHTTP/1.1 HTTP/1.1    2006
```

Defence In Depth

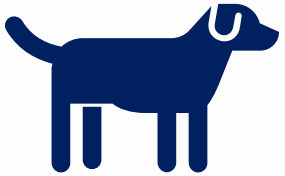
Defence In Depth

Defence In Depth

- We cannot rely on a single line of defence.
- Instead, we need to create multiple layers of defence at every level.
- There are 3 categories.
  - Physical
  - Technical
  - Administrative

Defence In Depth - Physical

- Things that you would employ at physical level.
- Technology like, sensors, locks, security guards, dogs, cameras, access cards etc.



Defence In Depth - Technical

- Things that you would employ at network, software level.
- There are various security devices that can be used, the most common ones are.
  - **Firewall**
  - **IDS**
  - **IPS**
  - **SIEM**
  - **VPN**
- Proper access control should be implements, principle of least privilege should be followed.

Defence In Depth - Administrative

- Things that you would employ on administrative level.

- Creating security centric

  - Policies
  - Procedures
  - Onboarding
  - Offboarding
  - Documents
  - Risk Management Plan
  - Incident Response Plan

SURAKSHYAAN

Zero Trust Model

Zero Trust Model

- Assumes threat exists both inside and outside the network.
- Never trust, always verify.
- No trust by default, even if user comes from a privileged network, always verify.
  - Example : Asking for current password at password change.

Zero Trust Model - Principles

1. Continuous Validation
2. Principle Of Least Privilege
3. Micro Segmentation
4. Monitoring

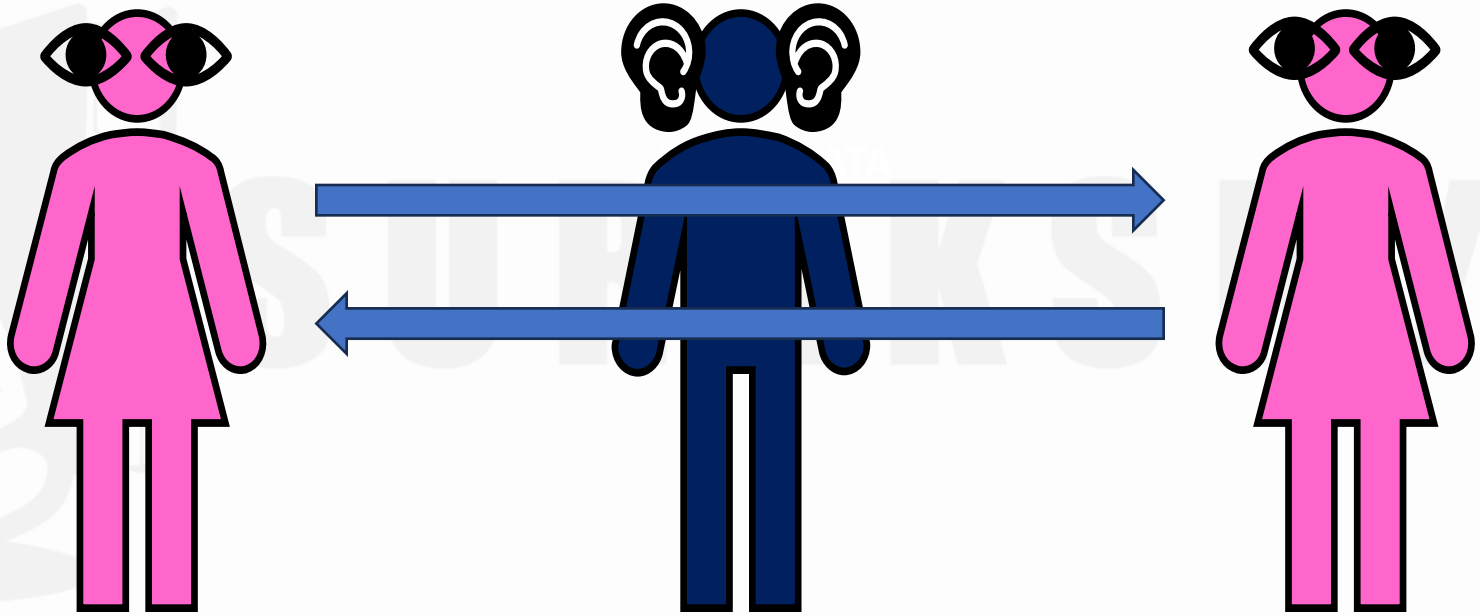
SURAKSHYAAN

Common Attacks

Man In The Middle Attack

Man In The Middle Attack

Man In The Middle Attack

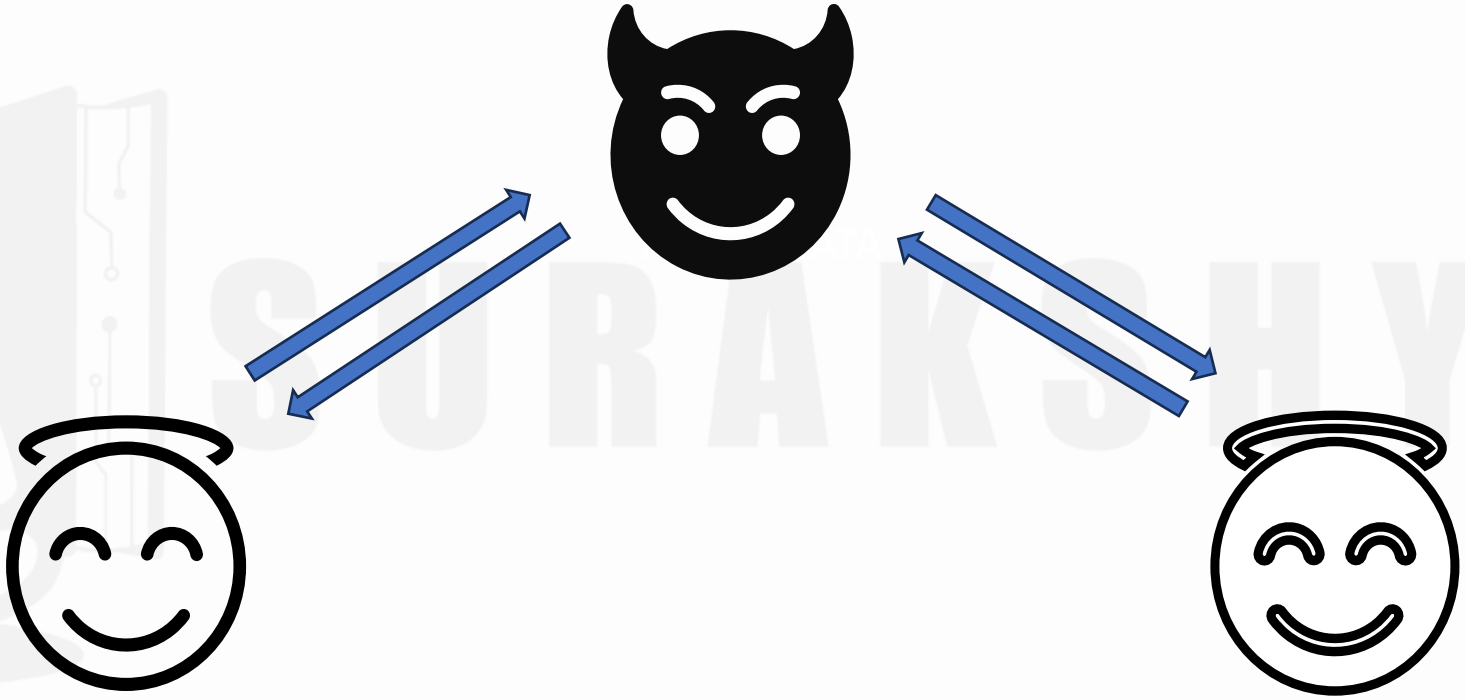


Man In The Middle Attack

- An attack where the attacker intercepts communication between two parties.
- Communication can be anything
  - A user’s device communicating with remove server.
  - A handwritten letter
  - Two people communicating over electronic telephone.
- Attack can either simply listen or make changes to the data.
- MITM Tool : Ettercap

Man In The Middle Attack

Man In The Middle Attack



How do we deal with MITM?

Digital Certificates

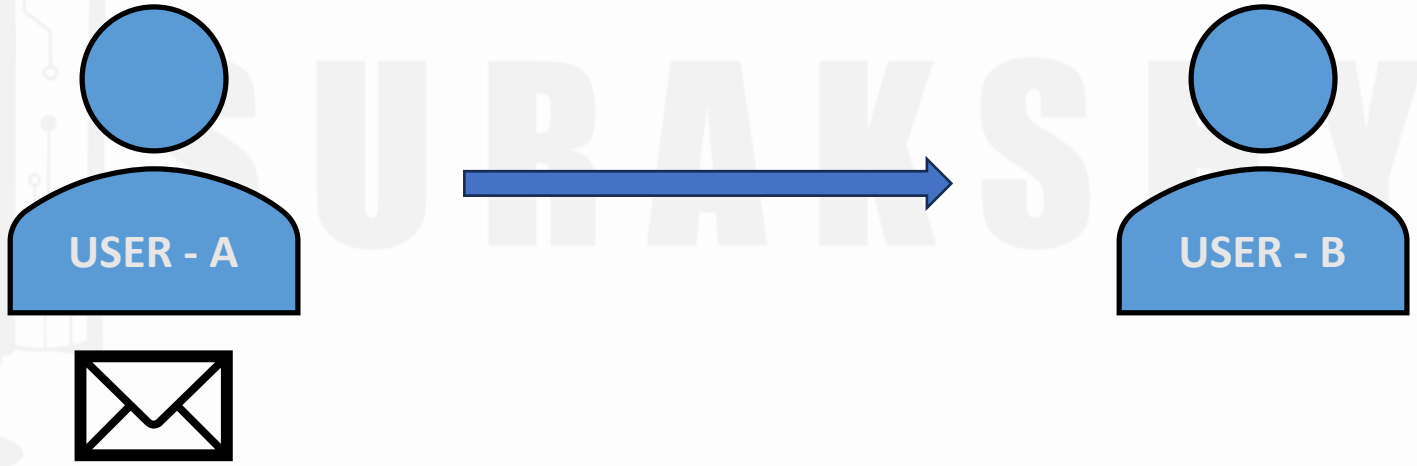
Digital Certificates

- A digital certificate is a digital identity that can be used to verify ownership of a server, software, network, email, document etc.

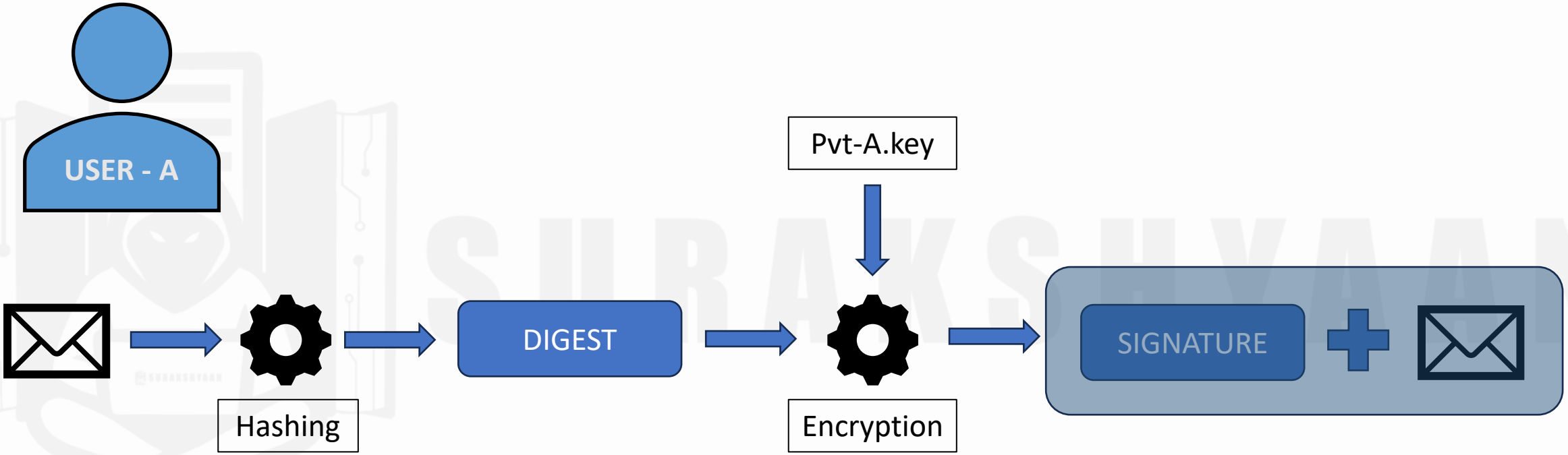
- Digital certificates use asymmetric encryption, i.e. a pair of keys is generated.

  - **Private Key** : Stays private to the user and is used to sign the document.
  - **Public Key** : Is made public and used to verify the signed document.

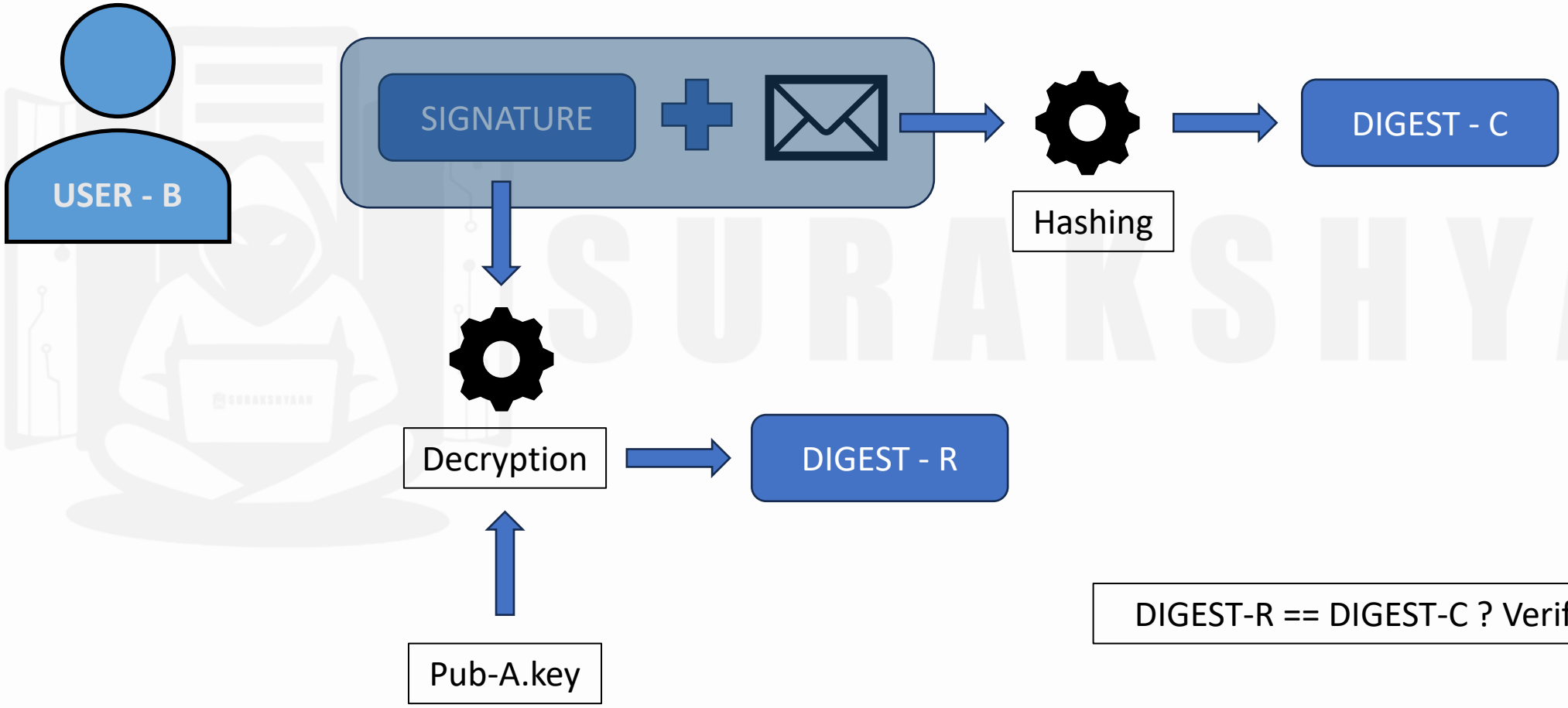
Digital Certificates



Digital Certificates



Digital Certificates



DIGEST-R == DIGEST-C ? Verified : Not Verified

Digital Certificates

- Example :
  - Software have digital certificates, that your system checks for, before installing them.

SURAKSHYAAN

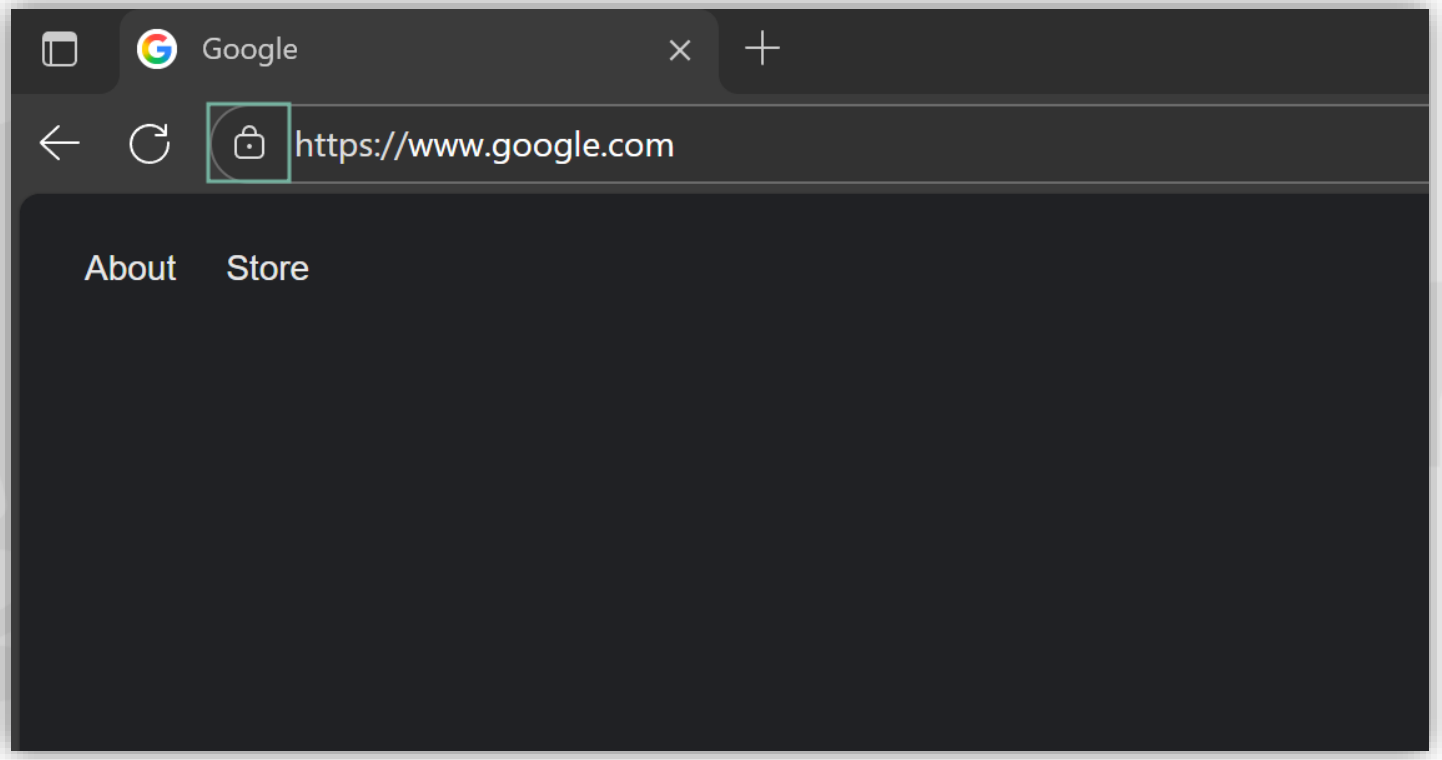
SSL : Secure Socket Layer

SSL

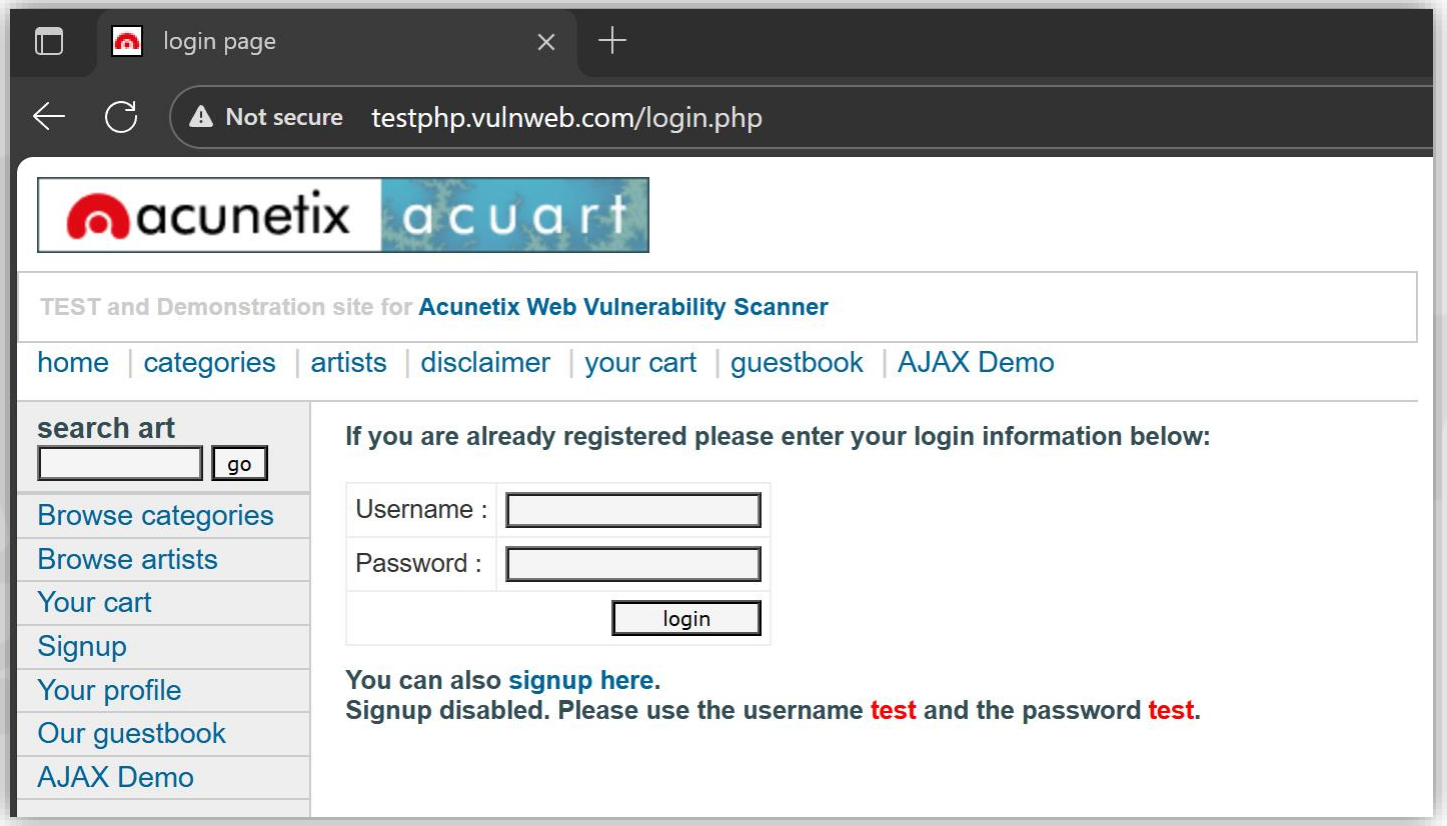
- SSL Stands for secure socket layer
- The reason why you are able to communicate with anyone on the internet without having to worry about someone eavesdropping.
- SSL allows your computer to verify the identity of remote server that you are talking to and vice versa (in some cases).
- It simply answers “If google.com you are communicating with, is indeed the real google.com”.
- SSL has now been replaced by a stronger alternative i.e. TLS.

SURAKSHYAAN

SSL



SSL


login page
Not secure
testphp.vulnweb.com/login.php
acunetix
acuart
TEST and Demonstration site for Acunetix Web Vulnerability Scanner
home | categories | artists | disclaimer | your cart | guestbook | AJAX Demo
search art
go
Browse categories
Browse artists
Your cart
Signup
Your profile
Our guestbook
AJAX Demo
If you are already registered please enter your login information below:
Username :
Password :
login
You can also signup here.
Signup disabled. Please use the username test and the password test.

SSL

- SSL employs both symmetric and asymmetric encryption. It uses
  - **Digital Signatures** : To verify digital identity.
  - **Asymmetric Encryption** : To exchange secret key before the communication starts.
  - **Symmetric Encryption** : To encrypt & decrypt traffic using the secret key during communication.

Passwords

Passwords

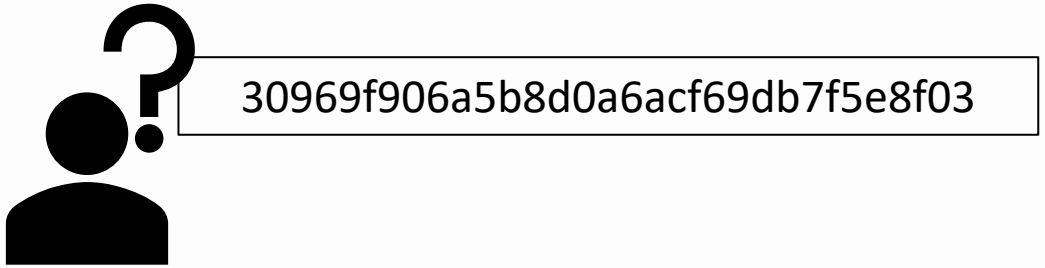
- A secret string that you use, to authenticate yourself.
- What's a strong password?
    - At least 12 characters, >12 even better.
    - A mix of uppercase and lowercase.
    - Should have special characters and numbers.
    - Should not contain common words.
- Check your password strength here.

Th1s1smys3curep@ssw0rd1!

Password Storage

Password Storage

- Every website stores user password, to verify them during authentication.
- It is very critical how the application stores a user's password, because "what's the point of a strong password, if it's anyway going to leak?".
- We have guidelines and best practices around how passwords should be stored in a database.
- Every password should be hashed, since hashes can't be reversed, even if the database is leaked, attackers won't have the original/plaintext password.



Rainbow Tables

- Hashes cannot be reversed, but they can be brute forced.
- A ***Rainbow Table*** is a table that contains precompiled list of hashes for most common passwords.

2a4bbeffd06c016ab4134cc7963496d2

Rainbow Table	
123456	bd5fc664d4a14a45a5660532d7a3e31d
Qwerty	2a4bbeffd06c016ab4134cc7963496d2
abcd1234	15c8a6dc3061129d08757ab5f2991689

Secure Password Storage

Salting

- Salting is a way to prevent against rainbow table attacks.
- A random salt string is prepended to the password before it is hashed.
- Each password has it's own salt and is stored along with the password in DB.

!ASD23@# + Password@123!

Database	
!ASD23@#	Hash(!ASD23@# + Password@123!)
*&$%$FDA	Hash(*&$%$FDA + qwerty@998!)
DGS$@%@	Hash(DGS$@%@ + Passwd@234!)

Peppering

- A common string is prepended to all passwords before they are hashed.
- Pepper string is not stored in DB, instead it is stored in some other storage.
- All the passwords will have a single pepper string.

Database
Hash(const_pepper_string + Password@123!)
Hash(const_pepper_string + qwerty@998!)
Hash(const_pepper_string + Passwd@234!)

Common Password Attacks

Password Brute-force

- Brute-forcing the user’s password either by brute-forcing each and every character or by using a pre-compiled dictionary of passwords.

- If the attacker chooses to brute-force each and every character one by one, then it is a pure brute force attack.

- If the attacker chooses to brute-force the user’s password using a dictionary, it’s called a Dictionary Attack.

SURAKSHYAAN

Password Brute-force

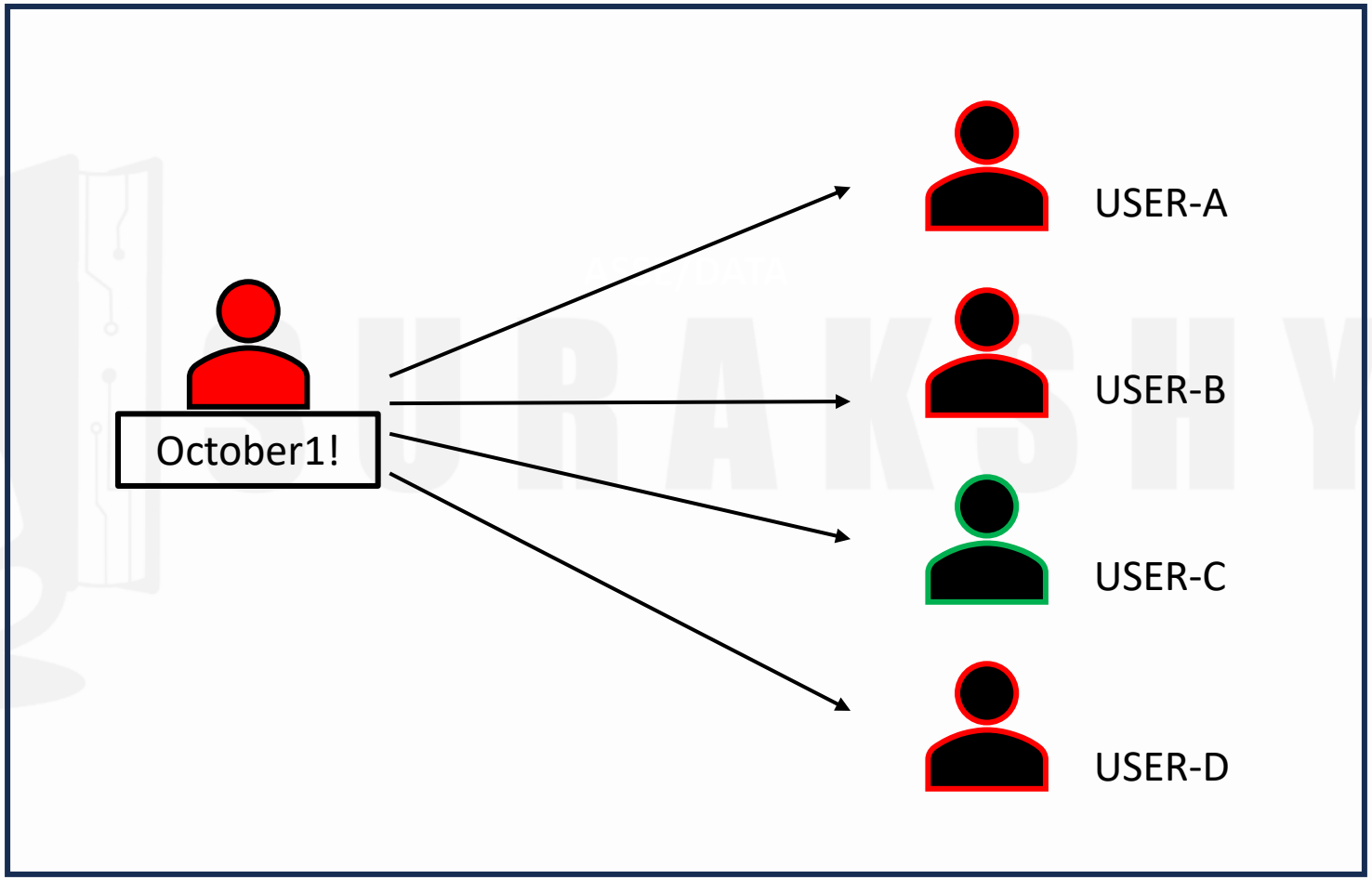
```
                    Aircrack-ng 1.7

[00:00:00] 19/23 keys tested (274.40 k/s)

Time left: 0 seconds                                      82.61%

                KEY FOUND! [ blackrockz09 ]


Master Key     : 2A B6 10 95 86 CC 79 8C B9 9F 16 B0 1E 0C 8F C3
                 29 D0 1E AE CD 66 DF BD 3E 02 A6 9F B7 F8 E8 BD

Transient Key  : 8B 52 C3 81 4B 68 94 7A 82 9A 04 E5 78 2A 77 6C
                 47 9A 24 BB CE 9E AD 00 00 00 00 00 00 00 00 00
                 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
                 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00

EAPOL HMAC     : 5F 98 37 37 40 39 89 1C 2C 02 BB B5 E8 01 77 3F
```

Password Spraying

- Attacker sprays a single password across multiple user accounts.
- Usually works in cases where default password is given to users.
- For Example: October1!

ASSE/DATA
SURAKSHYAAN

Password Spraying



Some Resources

- Have you been breached ?
  - https://haveibeenpwned.com/
  - https://databreach.com/
  - https://dehashed.com/

ASSE/DATA
SURAKSHYAAN

Social Engineering

Social Engineering

- Also known as *the art of human hacking*.
- A social engineering attack involves three components.
  - **Pretence** : A fake scenario and identity to build trust.
  - **Urgency** : Creating a sense of urgency that forces victim to take action.
  - **Action** : The action that the victim takes in response to that urgency.

Social Engineering – Example

- You receive a call from a malicious hacker, pretending to be your bank and he presents a situation where some X amount has been debited from your account.

Social Engineering Attacks

Social Engineering Attacks

- Phishing
- Vishing

ASSE/DATA
SURAKSHYAAN

Malware

Malware

- **Virus**
  - Damages or steals data, it can replicates itself.
- **Adware**
  - Displays ads on devices.
- **Ransomware**
  - Encrypts all the data and asks for a ransom in order to decrypt it.
- **Info Stealer**
  - Steals all the information like browser cookies, history, passwords etc.
- **Spyware**
  - Used to spy on a device.

Is your file malicious?

VirusTotal

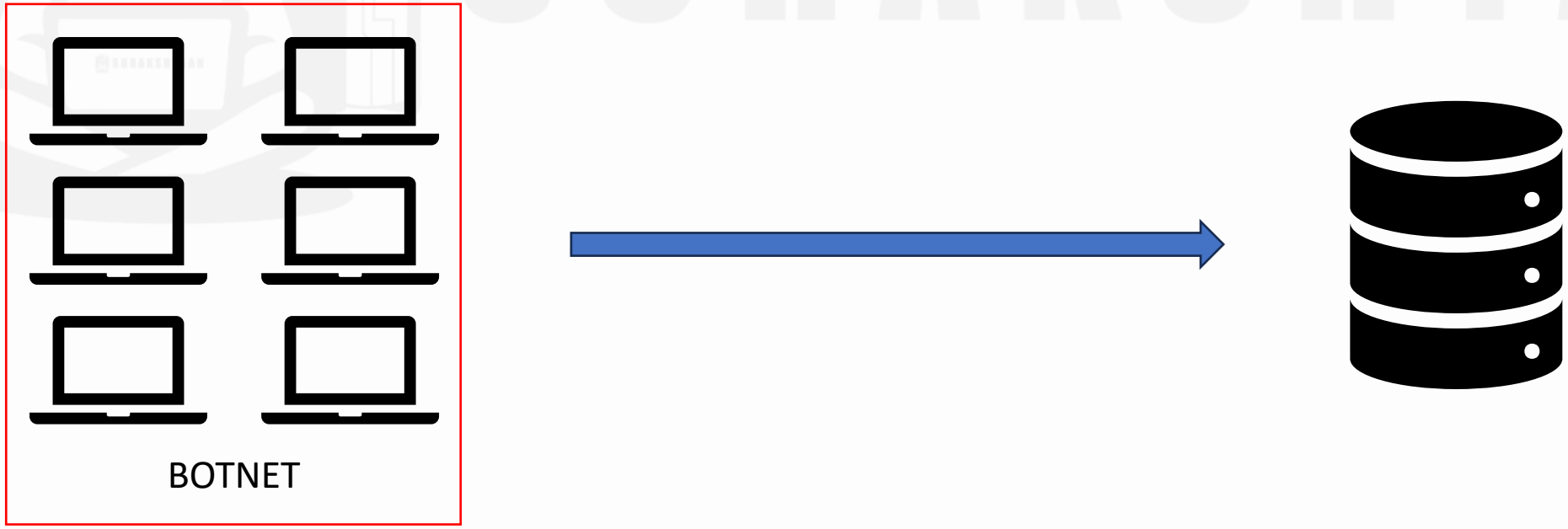
DOS & DDOS

Denial Of Service - DOS

- DOS stands for denial of service attacks.
- It refers to an attack where a server is overloaded with requests and fails to serve any client. It basically crashes.

Distributed Denial Of Service - DDOS

- DDOS stands for distributed denial of service.
- It’s a variation of DOS attack.
- Here’ the attacker uses a botnet to generate huge number of requests to overload the server.



Zero Days

Zero Days

- Zero day refers to a vulnerability that exists, but the developer is not aware about it.
- By `zero day` we are basically saying that the developer had 0 days to fix the issue, since he didn't know about it.
- **For Example** :
  - I have created a banking app, but there's a vulnerability that allows an attacker to view anyone's account balance and I am not aware about it. So we can say, the attacker exploited a 0-day vulnerability in my application to view anyone's balance.

ASSE/DATA SURAKSHYAAN

APT

APT

- APT stands for *advanced persistent threat*.
- It refers to a particular group of threat actors(malicious hackers) that are very sophisticated and well resourced.
- These groups tend to pull off cyber attacks on high value systems and networks over a prolonged period.
- These groups are usually state-sponsored.
  - Each group is given a unique identifier, for example: APT-38, Lazarus Group : North Korean Threat Actor.

Disclosure Programs

Disclosure Programs

- Some companies maintain a vulnerability disclosure program, that allows security researchers to submit bugs to these companies.
- In return companies either pay bounties to these researchers (bug bounty) or they put up the researcher's name in their hall of fame page.
- There are platforms like `HackerOne`, `Bugcrowd` etc. You can browse companies and submit bugs.

SIRAKSHYAAN

Week – 3

Presented By : A3h1nt

OSINT

OSINT

- OSINT stands for open-source investigation.
- It refers to the practice of collecting data from open sources online.
- OSINT is a very strong tool, it allows you to find things like email, number, family members, professional life, photos, address and maybe even their password.

Basic Cyber Hygiene

Basic Cyber Hygiene

- Use strong passwords.
- Do not reuse passwords.
- Use a password manager to manage passwords (Keychain or Bit warden)
- Do not download or run pirated software, nothing is free :)
- Turn off internet on your devices when you are not using them.
- Do not click on random links, be mindful about it.
- Always verify, before taking any action, call the bank on their official helpline and confirm it before sharing any information.

SURAKSHYAAN

Websites To Get Familiar With

- **Exploit-DB**
  - A database of exploits & research papers.

Websites To Get Familiar With

- **OWASP**
  - Stands for open worldwide application security project.
  - Contains guidelines, procedures, documentations related to web security.
  - Talk about OWASP top-10 list, a list of most common and critical bugs.

SURAKSHYAAN

What to do next?

What to do next?

What you know	Next Step	After that
Nothing	Networking	Linux
Networking	Linux	Web Basics
Networking & Linux	Basic Web Vulnerabilities / Basic Network Vulnerabilities / OSINT / Threat Intel	Mobile / API / Thick Client / AD / Reversing /